Incident Analysis: ICMP Flood DDoS (NIST CSF)

Using the NIST Cybersecurity Framework to build a security improvement plan

Type	Incident report analysis
Framework	NIST Cybersecurity Framework (CSF)
Skills	Incident analysis, applying a framework, security planning, writing a playbook
Source	Google Cybersecurity Professional Certificate, Course 3 (*Connect and Protect: Networks and Network Security*)

Summary

A multimedia company that offers web design, graphic design and social media marketing services was hit by a **distributed denial-of-service (DDoS) attack**. A flood of **ICMP packets** stopped internal network services from responding for **two hours**. The incident management team blocked incoming ICMP, took non-critical services offline and restored critical services. The investigation found that the attacker sent the ICMP traffic through an **unconfigured firewall**.

The network security team then added: a firewall rule to **rate-limit incoming ICMP**; **source IP verification** to detect spoofed addresses; **network monitoring** for unusual traffic patterns; and an **IDS/IPS** to filter suspicious ICMP traffic.

NIST CSF analysis

Function	Analysis and plan
Identify	**What was attacked:** the internal network and every service that depends on it. **Vulnerability:** a firewall that had been deployed without a rule set, along with no configuration baseline or review process that would have caught it. **Plan:** keep an inventory of network devices and their configurations; run regular audits of firewall rules, systems and access privileges; add “device deployed with default or no configuration” to the risk register.
Protect	**Hardening:** make the new firewall settings (ICMP rate limiting, source IP verification and anti-spoofing) the **standard baseline for all firewalls**. **Change management:** no network device goes live without a reviewed configuration. **Architecture:** segment the network so critical services are isolated and one flood can’t take down everything. **Training:** train network staff on secure configuration and

Function	Analysis and plan
	change control.
Detect	Network services stopped *suddenly*, which shows nothing warned the team as the flood built up. **Plan:** tune the new network monitoring to alert on traffic spikes (ICMP volume, packets per second per source); run the IDS/IPS in **prevention mode** with DoS signatures; send firewall, IDS and monitoring logs to a central SIEM so related events are correlated.
Respond	The team's actions (blocking ICMP, stopping non-critical services, restoring critical ones) worked but were improvised. **Plan:** write them up as a **DDoS response playbook** with clear roles; set communication channels for management, staff and clients; run a **post-incident review** on why the firewall was unconfigured and how spoofed traffic got through; keep the logs as evidence.
Recover	**Plan:** document the recovery order (critical services first); test recovery regularly against a target time well under the two hours this incident took; consider an upstream or cloud **DDoS-mitigation service** to absorb future floods; feed the lessons learned back into Identify and Protect.

Note on CSF 2.0

The current version of the framework (NIST CSF 2.0, released in 2024) adds a sixth function, **Govern**. In this incident, Govern would cover ownership of the firewall and network security policy, and who approves configuration changes. The missing ownership and approval is the gap that let an unconfigured firewall reach production.

Reflection

The technical root cause (no firewall rules) was simple. The NIST CSF helped me show that it was really a *process* failure across several functions: nothing identified the gap, no baseline protected against it, and no monitoring detected the attack early. The plan above fixes the process, not just the one device.